

BÁO CÁO TIẾN ĐỘ THỰC HIỆN ĐỒ ÁN - TUẦN 9

1. Tình hình phát triển và Tối ưu hóa hệ

loại bỏ hoàn toàn sự phụ thuộc vào cấu hình thủ công (Manual Whitelisting) và nâng cấp danh sách đen thành tự động để đảm bảo tính công bằng và tính thực tiễn cao nhất.

- Nâng cấp Danh sách đen Động

- Vấn đề cũ: Lớp 2 (Blacklist) chỉ dựa vào một file tĩnh dangerous_urls.json gồm hơn 100 URL, khiến hệ thống không thể bắt kịp các chiến dịch lừa đảo mới phát sinh hàng giờ.
- Giải pháp: Tích hợp nguồn dữ liệu thời gian thực từ Phishing.army - dự án mã nguồn mở chuyên tổng hợp danh sách đen từ các tổ chức bảo mật lớn trên thế giới (Cert.pl, Urlscan.io).

- Xây dựng Thuật toán chấm điểm uy tín

- Tinh chỉnh thuật toán Phân tích Nội dung

Cải tiến hàm quét thẻ tín dụng, yêu cầu bắt buộc trang web phải chứa thẻ <form> và <input> nhạy cảm, giúp triệt tiêu báo động giả trên các trang SaaS có chữ 'billing'.

- Tích hợp tính năng Gỡ lỗi chuyên sâu

Xây dựng cơ chế DEBUG_MODE ghi log chi tiết luồng thực thi 8 lớp, trích xuất ma trận 39 đặc trưng thô, chứng minh hệ thống có khả năng tự sửa sai thiên kiến (bias) của AI hoàn toàn tự động.

- Tích hợp Nhận diện Mã độc chủ động

- Vấn đề: Thuật toán Harmless Page trước đây chỉ kiểm tra form mật khẩu. Nếu trang lừa đảo phát tán mã độc (Malware Dropper) yêu cầu tải file .exe hoặc .apk, trang web sẽ bị đánh giá nhầm là vô hại và bị giảm rủi ro.

Cải tiến Lớp 6 (DOM Analysis) để quét toàn bộ các thẻ liên kết (HREF). Nếu phát hiện URL trỏ trực tiếp đến các tệp thực thi nguy hiểm (.exe, .apk, .bat, .msi,

.cmd, .dmg), hệ thống lập tức tước bỏ quyền 'Trang vô hại' và cộng thêm 0.5 điểm rủi ro, kết hợp với điểm ML để chặn đứng trang web.

Khắc phục Lỗ hổng Ký sinh Đám mây

- Vấn đề: Kẻ tấn công lợi dụng các nền tảng đám mây miễn phí (Azure, Firebase, Github Pages) để host trang phishing. Do tên miền gốc (ví dụ windows.net) có tuổi đời hàng chục năm, Lớp 7 (Domain Age) đã bị đánh lừa và áp dụng giảm trừ rủi ro (Reputation Bonus) cực lớn, gây ra lỗi bỏ lọt (False Negative).

Phát hiện trang lừa đảo 'arubawebmailsession82.blob.core.windows.net' được AI chấm rủi ro cao, nhưng bị Lớp 7 hạ xuống mức An toàn vì nhận diện nhầm tuổi domain là 11227 ngày (tuổi của Microsoft). Hệ thống đã được vá lỗi bằng cách lập danh sách đen các nền tảng 'Shared Hosting'. Mọi URL nằm trên các nền tảng này sẽ bị từ chối đặc quyền tra cứu tuổi domain, buộc phải chịu mức đánh giá rủi ro nguyên bản từ AI.

3. Nghiên cứu cơ sở lý thuyết và tham chiếu quốc tế.

Trong tuần này, em đã nghiên cứu sâu văn bản thực tế của bài báo 'Optimizing Phishing URL Detection with Xgboost' (M. Nagaraju et al.). Tài liệu cung cấp các nền tảng toán học quan trọng để tối ưu hóa hệ thống.

Lựa chọn đặc trưng bằng Tương quan Thông tin (Mutual Information - MI)

Nghiên cứu sử dụng chỉ số MI để định lượng mức độ đóng góp của từng đặc trưng vào nhãn mục tiêu.

Hệ thống tính toán MI giữa đặc trưng X_j và nhãn Y dựa trên phân phối xác suất đồng thời $P(x,y)$. Việc áp dụng MI giúp loại bỏ các đặc trưng dư thừa, giảm chiều dữ liệu mà không làm mất đi các mẫu (patterns) quan trọng, tương đồng với cách em lọc từ 87 xuống 39 đặc trưng tối ưu nhất.

Tối ưu hóa Siêu tham số qua Bayesian Optimization

Thay vì thử nghiệm ngẫu nhiên, nghiên cứu đề xuất sử dụng hàm thu nạp (Acquisition Function) để tìm bộ tham số θ^* tối ưu.

$\theta^* = \arg \max E[f(\theta)]$. Phương pháp này giúp mô hình đạt độ chính xác 96.5% với chi phí tính toán thấp nhất, chứng minh tính hiệu quả của bộ tham số em đã chọn (Max depth=5, Learning rate=0.01).

Biện luận về hiệu năng thực tế (XGBoost vs. Deep Learning vs. Random Forest)

Tài liệu cung cấp số liệu thực nghiệm để bảo vệ kiến trúc Offline của đồ án:

- So với Deep Learning: XGBoost huấn luyện chỉ mất 15 giây (so với 180 giây của LSTM), tiết kiệm tài nguyên đáng kể cho thiết bị người dùng.
- So với Random Forest: Tuy RF huấn luyện nhanh hơn, nhưng XGBoost có tốc độ dự đoán (Inference) nhanh hơn 14% nhờ thuật toán nhận biết độ thưa (Sparsity-Aware).

Random Forest dựa trên chỉ số Gini Impurity để chia nút song song. XGBoost sử dụng khai triển Taylor bậc hai để tối ưu hàm mục tiêu theo chuỗi, giúp bắt được các đặc trưng phishing tinh vi mà RF thường bỏ lọt.

4. Kế hoạch tuần tới (Tuần 10)

- Đóng gói mã nguồn Extension hoàn chỉnh.